NexaPair × KAYAK STRATEGIC ADVISORS

WHITE PAPER



WHITE PAPER · NOVEMBER 2026

Article 13, made practical

A field guide to third-party risk management under the Central Bank of the UAE's Operational Risk Management Regulation, C 1/2026.

Published by NexaPair and Kayak Strategic Advisors Private Limited · nexapair.ae · NP-WP-2026-01

November 2026

CONTENTS

In this paper

· At a glance 3
01 Why regulators focused on third parties 4
02 What the regulation asks, article by article 6
03 Who does what: the department dial 9
04 A 90-day plan, and the value it returns 11
06 Readiness self-check and glossary 12
07 How NexaPair and Kayak can help 13



Third-party risk is a team sport: procurement, legal, risk and operations each own a part. Photo: Pexels.

FOREWORD

Regulation C 1/2026 does not invent a new discipline. It raises the standard of evidence.

Questionnaires, annual reviews and contract folders are no longer enough on their own. The Central Bank of the UAE expects a live register, risk-based due diligence before engagement, contracts that guarantee access and audit, continuous monitoring, tested exit plans and fast incident reporting.

This paper turns those expectations into work: what each article asks, the evidence that satisfies it, who usually owns it, and a 90-day plan to get ready. It closes with a self-check you can take to your next risk committee.

Who this paper is for

Chief Risk Officers, heads of procurement, compliance, information security, operations and internal audit at institutions licensed by the Central Bank of the UAE, and the Board members who oversee them.

How to read it

Article numbers follow the regulation; wording is paraphrased. Always check the official text in the CBUAE Rulebook before relying on a summary.

AT A GLANCE

The regulation in four numbers

14 Sep
2026: the date Regulation C 1/2026 came into force.

18
third-party requirements mapped in this paper, from Board oversight to incident reporting.

4 h
to notify the Central Bank of an event that significantly affects a Critical Operation.

90
days: a realistic plan to see, check and prove your third-party controls.

Executive summary

The Central Bank of the UAE's Operational Risk Management Regulation, C 1/2026, has been in force since 14 September 2026. It makes the management of third parties part of each institution's own operational resilience, and it keeps the Board accountable for work that is outsourced.

For most institutions the regulation raises the standard of evidence rather than the scope of the work. Supervisors will want to see the register, the due diligence file behind each critical provider, the contract clauses that guarantee access and audit, the monitoring that runs between reviews, the exit plan and its last test, and a record that incidents were notified on time.

Done well, this work pays back: fewer disruptions, less fraud and leakage, faster onboarding, better negotiating positions and fewer costly remediation projects. Section 05 explains how.

> *The Board stays accountable for what is outsourced. The evidence has to show it.*
>
> THE PRINCIPLE BEHIND ARTICLES 4 AND 13

FIVE THINGS TO DO FIRST

1. Get a Board-approved third-party risk strategy and policy in place **13.1**
2. Build one register of outsourced activities and keep it current **13.9.1**
3. Map which third parties support your Critical Operations **3.4, 13.10**
4. Check every material contract for audit, access, termination and subcontracting terms **13.6–13.8**
5. Rehearse the 4-hour incident notification with your critical vendors **15**

01



CONTEXT

Why regulators focused on third parties

Institutions now depend on a long chain of providers. When one of them fails, customers see the institution fail.

IN BRIEF

- Single incidents at providers have reached thousands of organisations at once.
- Concentration on a few technology providers adds systemic risk.
- Financial crime uses the same routes as legitimate supply.
- Supervisors worldwide, now including the CBUAE, have raised the bar.

Financial institutions now depend on a long chain of providers: cloud platforms, payment processors, core banking and software vendors, call centres, sales agents and data providers. Customers experience the work of these providers as the bank's own. When one of them fails, the bank fails its customers.

Recent years showed how far a single weak link can reach. A compromised software update in 2020, a breached file-transfer tool in 2023 and a faulty security update in July 2024 each spread to thousands of organisations at once. Concentration adds to the risk: many institutions rely on the same small group of technology providers.

Financial crime follows the same routes. Fake vendors, conflicts of interest between staff and suppliers, and intermediaries that move money for sanctioned parties are all third-party risks.

Supervisors have responded worldwide. The Basel Committee published principles for operational resilience in 2021, and the European Union's Digital Operational Resilience Act has applied since January 2025. Regulation C 1/2026 brings the UAE in line with this direction.

THE DIRECTION OF TRAVEL

2020	A compromised software update reaches thousands of organisations.
2021	Basel Committee principles for operational resilience.
2023	A breached file-transfer tool exposes data across sectors.
2024	A faulty security update stops systems worldwide in July.
2025	EU DORA applies from January.
2026	CBUAE Regulation C 1/2026 in force from 14 September.

> *Customers experience the work of providers as the bank's own. When one of them fails, the bank fails its customers.*

Three ways a third party fails you

It stops

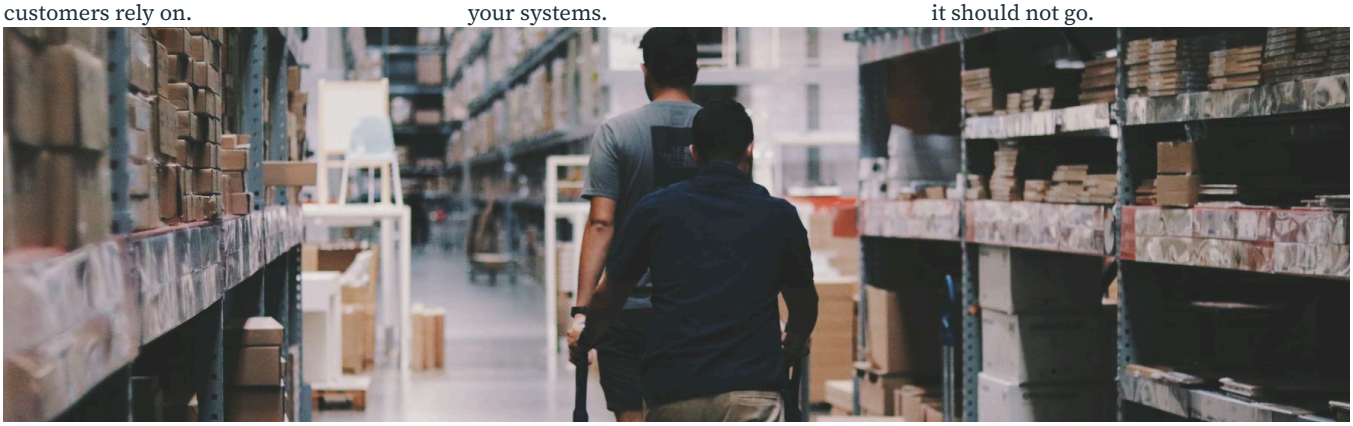
An outage, a faulty update or an insolvency interrupts a service your customers rely on.

It leaks

A breach at a provider exposes your customers' data, or opens a route into your systems.

It deceives

A fake vendor, a diverted payment or an undeclared conflict moves money where it should not go.



Supply chains are long: the provider you contract with depends on providers of its own. Photo: Pexels.

02



THE REQUIREMENTS

What the regulation asks, article by article

Article 13 follows the life of a third-party relationship. Each stage asks for its own evidence.

IN BRIEF

- Eighteen requirements, from Board oversight to incident reporting.
- Five of them are about governance, before any vendor is chosen.
- Monitoring is continuous, not an annual review.
- Exit and incident plans must work, and be shown to work.

02 · THE REQUIREMENTS

Article 13 follows the life of a third-party relationship. Read it as six stages, each with its own evidence.

Govern — Policy, appetite, concentration · 13.1, 13.2

Select — Tiering and due diligence · 13.3, 13.4

Approve — Central Bank non-objection · 13.5

Contract — Rights, access, flow-down · 13.6–13.8

Monitor — Register, metrics, dependencies · 13.9

Exit & respond — BCP, exit, incidents · 13.10–13.12, 15

Article	What it requires	Evidence that works	Usual owner
4.1, 4.2	The Board is ultimately responsible for operational risk, including outsourced activities, and oversees it.	Board minutes approving the policy; regular Board reporting on third-party risk.	Board, CRO
3.4	Map Critical Operations, including the third parties that support them.	A current map linking each Critical Operation to its people, systems and providers.	Operations, Risk
8.9	Keep the master system of record in the UAE, including where activities are outsourced.	Data-location records per system and provider; contract clauses on data location.	IT, Legal
13.1	A Board-approved third-party risk strategy and policy.	Approved policy, risk appetite, tiering method and approval chains.	Risk, Board
13.2	Avoid over-reliance on outsourcing.	Concentration and single-source analysis; dependency reporting.	Risk, Procurement
13.3	Assess risk and carry out due diligence before engaging.	Tiering result; due diligence file proportionate to the tier, completed before signature.	Procurement, Compliance
13.4	Providers of Critical Operations must offer equivalent operational resilience.	Recovery objectives compared with your disruption tolerances; test results.	Operations, IT

Where the eighteen requirements sit



Requirements mapped in this paper, by lifecycle stage. Count of rows in the table on these two pages.

READING THE TABLE

Article numbers follow Regulation C 1/2026; wording is paraphrased. The owner column is a common pattern, not a rule: name a person for each row.

02 · THE REQUIREMENTS, CONTINUED

Article	What it requires	Evidence that works	Usual owner
13.5	Obtain the Central Bank's non-objection before outsourcing that affects Critical Operations.	Non-objection on file before go-live; a gate in your onboarding workflow.	Compliance
13.6	Written contracts covering rights and obligations, data ownership, confidentiality, termination, and inspection and audit rights.	Clause checklist per contract; exceptions approved and recorded.	Legal
13.7	Central Bank access to the provider, including on-site examination.	Access clause in every relevant contract.	Legal
13.8	Subcontractors are bound by the same access and contract terms.	Flow-down clauses; a register of material subcontractors.	Legal, Procurement
13.9.1	Maintain a register of outsourced activities.	One complete, current register (see the NexaPair register workbook).	Procurement, Risk
13.9.2, 13.9.3	Monitor performance with metrics and assess providers on an ongoing basis, including financial condition.	Service-level data, review records, financial-health monitoring, screening alerts.	Business owners, Risk
13.9.4	Manage dependencies.	Dependency and relationship analysis, including links to your own staff.	Risk
13.10	Business continuity planning that covers Critical Operations and their providers.	BCPs referencing providers; joint tests.	Operations
13.11	Contingency and exit plans, considering how substitutable the provider is.	Exit plan per material arrangement, with alternatives and a test date.	Business owner, Procurement
13.12	The Central Bank may require an arrangement to be discontinued.	An executable exit plan and off-boarding procedure.	Business owner
15.2, 15.3	Notify operational risk events affecting Critical Operations within 4 hours; summary within 24 hours; notice of return to normal; high-risk incidents reported within 72 hours.	Incident playbook agreed with providers; prepared notice formats; time-stamped records.	Operations, Compliance

WHAT GOOD EVIDENCE LOOKS LIKE

Dated, attributable and reproducible: a record shows who decided, on what information, and when, and the same check run again gives the same answer.

> *If it is not recorded, it did not happen. Supervisors test the trail, not the intention.*

QUESTIONS FOR THE BOARD

- Which third parties could stop a Critical Operation tomorrow?
- When did we last test an exit from one of them?
- How many material contracts still lack Central Bank access terms?
- Could we notify the Central Bank within four hours today?



Evidence is dated, attributable and reproducible. Photo: Pexels.

03



OPERATING MODEL

Who does what: the department dial

Third-party risk fails when it belongs to one team. It works when every department does a small, clear part.

IN BRIEF

- Ten functions each hold part of the evidence.
- Finance knows who is paid; HR knows who works here; Legal knows what was signed.
- One register joins the fragments into one file per third party.
- The Board approves the policy and sees the results.

03 · OPERATING MODEL

Ten departments, one evidence trail

Procurement: Bring vendors in cleanly

Register the vendor, choose the service, send the supplier questionnaire, keep the register current.

Finance: Pay the right party

Confirm the bank-account owner before the first payment; hold payments when details do not match.

Legal: Contracts that hold up

Check audit, Central Bank access, data, termination and subcontracting clauses before signature.

Compliance: Screen and decide

Sanctions, PEP, adverse media and litigation checks; record each decision with its evidence.

Information Security: Safe access

Assess data and system access; set access levels; review security findings.

Operations: Resilience

Map Critical Operations; compare recovery times with tolerances; own exit plans.

HR: Conflicts of interest

Keep the employee list current so links between staff and vendors can be found.

Risk: The model

Set tiers, weights and thresholds; report to the Board; approve exceptions.

Internal Audit: Assurance

Sample decisions and test the evidence trail.

Board: Oversight

Approve the policy and related-party arrangements; review the Board pack.

WHY A DIAL, NOT A SILO

Each department already holds part of the evidence: Finance knows who is paid, HR knows who works here, Legal knows what was signed. The dial turns those fragments into one file per third party.

> *One register, many owners, one evidence trail.*

QUESTIONS TO START WITH

01 Who owns the register, by name?

02 Which department would notice a vendor's bank details change?

03 Does HR's employee list reach the people checking conflicts?

04 · READINESS PLAN

A 90-day readiness plan

See what you have, check it against the regulation, then prove it works. Each phase ends with something the Board can see.

DAYS 1 TO 30
See

- Collect every contract and supplier list into one register.
- Agree the tiering method and the Critical Operations list.
- Draft the policy for Board approval.
- Load the employee list for conflict checks.

Board sees: the draft policy and the first register.

DAYS 31 TO 60
Check

- Tier every third party; verify critical and high-tier vendors at the source.
- Review contracts for the required clauses; plan remediation.
- Map providers to Critical Operations and compare recovery times.
- Agree incident notification steps with critical vendors.

Board sees: the gap list and the remediation plan.

DAYS 61 TO 90
Prove

- Switch on continuous monitoring.
- Write and test exit plans for the most critical providers.
- Run a 4-hour notification drill.
- Present the first Board pack.

Board sees: test results and the first Board pack.

30 days to one register and a draft policy

60 days to a tiered, verified vendor base

90 days to tested exits and a 4-hour drill

05 · VALUE

From cost to value

Fewer disruptions
Weak or over-stretched suppliers are found before they fail you.

Less fraud and leakage
Fake vendors, wrong account owners, duplicates and staff conflicts are caught before money leaves.

Faster onboarding
Data verified at the source replaces weeks of chasing documents.

Better buying
One register shows exactly whom you depend on and what you pay.

Fewer penalties
Evidence is ready before the regulator asks.

Better use of experts
Routine checks are automated; specialists spend their time on judgement.

06 · SELF-CHECK

Readiness self-check

Answer yes or no. Each "no" is a priority for the next quarter.

#	Question	Article	Answer
1	Has the Board approved a third-party risk strategy and policy in the last twelve months?	13.1	☐ Yes ☐ No
2	Do you have one register of outsourced activities that is complete today?	13.9.1	☐ Yes ☐ No
3	Can you name the third parties behind each Critical Operation?	3.4, 13.10	☐ Yes ☐ No
4	Is due diligence always completed before signature, at a depth set by risk tier?	13.3	☐ Yes ☐ No
5	Do critical providers' recovery times sit within your disruption tolerances?	13.4	☐ Yes ☐ No
6	Is Central Bank non-objection on file for every arrangement that needs it?	13.5	☐ Yes ☐ No
7	Do all material contracts include audit, Central Bank access, data, termination and subcontracting terms?	13.6–13.8	☐ Yes ☐ No
8	Are vendors re-screened automatically, including financial condition?	13.9.3	☐ Yes ☐ No
9	Is there a tested exit plan for every critical provider?	13.11	☐ Yes ☐ No
10	Could you notify the Central Bank within four hours of a third-party incident today?	15	☐ Yes ☐ No

SCORING

8 to 10 "yes": ready to evidence. 5 to 7: close the gaps this quarter. 4 or fewer: start with the five first steps on page 3.

GLOSSARY

Critical Operations: operations whose disruption would cause significant harm to customers, the institution or the financial system. **Disruption tolerance:** the maximum disruption accepted for a Critical Operation. **Substitutability:** how easily a provider could be replaced. **Master system of record:** the authoritative source of an institution's records. **Non-objection:** the Central Bank's confirmation that it does not object to a proposed arrangement.



07

HOW WE CAN HELP

NexaPair and Kayak Strategic Advisors

NexaPair is the platform; Kayak Strategic Advisors brings the advisory judgement. Each solution maps to the articles it helps you evidence.

13.3 · 13.9.1

NexaVerify

Know who you are paying before anyone signs.

13.9.4 · 4.1

NexaGraph

Find the links nobody declared.

13.9.3 · 15

NexaSentinel

Hear about it first, and meet every clock.

FTA SUPPLIER CHECKS

NexaVatVeri

Protect your input VAT under the FTA's supplier checks.

13.4 · 13.9.3

NexaCybe

An outside-in cyber grade for every vendor.

13.1 · 13.6

NexaComply

Compliance management for any country's laws, with the UAE pre-loaded.

ARTICLES 3.4 TO 15

NexaPair UAE

The full third-party risk platform for the UAE, with the FTA rules built in.

TALK TO US

Start with a readiness review

We map your register against Article 13 and give you a prioritised gap list.
advisory@kayaksa.com



NexaPair × KAYAK STRATEGIC ADVISORS

ABOUT NEXAPAIR

NexaPair is a third-party risk management platform for the UAE, hosted in a UAE cloud region. It verifies, screens, monitors and scores the companies an institution depends on, and keeps the evidence a regulator expects.

ABOUT KAYAK STRATEGIC ADVISORS

Kayak Strategic Advisors Private Limited (CIN U70200MH2026PTC477060) is a management consultancy based in Mumbai. It builds and runs NexaPair, pairing advisory judgement with software.

OFFICE
Mumbai, Maharashtra, India

EMAIL
advisory@kayaksa.com

PHONE
+91 7710 828 028

Important notice. This publication contains general information only. It is not legal, regulatory, tax or other professional advice and should not be relied on as such; regulations are summarised and paraphrased and may have changed. Refer to the official texts (for the CBUAE, rulebook.centralbank.ae) and take advice for your organisation. Responsibility for compliance stays with each institution. You may share this publication in full with attribution.

Photography: Pexels (pexels.com/photo/7581326, 3184292, 1117210, 1797428, 1467300, 590016, 416405, 3184465), used under the Pexels licence. NexaPair and the NexaPair logo are marks of Kayak Strategic Advisors Private Limited. © 2026 Kayak Strategic Advisors Private Limited. All rights reserved.